CWE AI Working Group: Existing CWE Analysis/Modification Subgroup
August 29, 2025

Attendance

Steve Christey Coley
Erick Galinkin
Michael Simon
Ray Pompon
Monika Akbar
Mirzah Ali
Carolina Rocha

Agenda

- Status Updates
- Detailed Discussion: Getting Examples of “General” CWEs That Affect AI/ML Products

Meeting Notes:

Status Updates

Steve announced that the release date for CWE 4.18 has been delayed but is now set for September 9th. This update will influence the contents of CWE 4.18.

Steve discussed the backlog of five to seven AI-related submissions in the content development repository (CDR) and suggested splitting the work between the new entry working group and the modifications group.

- Erick proposed an asynchronous triage process to handle the backlog more efficiently, suggesting that new submissions be sent out to the mailing list for initial comments and triage. Erick emphasized the importance of providing initial feedback to submitters, even if it is just to determine whether a submission should be a new entry or a modification.

Michael emphasized the need to publish the workflow for handling AI-related submissions to ensure everyone is aware of the process and expectations. Steve explained the current workflow and how it might be modified to include more working group involvement.

Detailed Discussion: Getting Examples of “General” CWEs That Affect AI/ML Products

Steve shared the results of an exploratory analysis of CVEs related to AI and machine learning products, using data from the National Vulnerability Database (NVD) collected from the past year. The analysis identified common CWE mappings such as deserialization, path traversal, and resource consumption, among others.

- **Data Challenges:** Steve noted challenges such as false positives and incorrect CWE mappings, emphasizing that the data does not need to be perfect but should guide the direction of further analysis.
- **Next Steps:** Steve suggested prioritizing the identified CWE mappings for updates and considering observed examples from the analysis for inclusion in CWE entries.

Steve outlined the criteria for selecting good observed examples for CWE entries, emphasizing the need for clear, understandable technical details, which should include clear descriptions of the weaknesses and relevant and understandable attack scenarios, as well as a diversity of products and attack surfaces.

Steve and Erick discussed a recent CVE example involving prompt injection in GitHub Copilot, which could serve as a useful observed example for CWE entries. The example was found to be well-documented and relevant.

Steve proposed finalizing and sharing the collected data with the working group early next week. This will include examples of good and not-so-good observed examples to guide the group's efforts.

- **Data Finalization:** Steve proposed finalizing the collected data and sharing it with the working group early next week.
- **Example Sharing:** The shared data will include examples of good and not-so-good observed examples to guide the group's efforts in selecting relevant examples for CWE entries.

Action Items:

- **Workflow Sharing:** Share the current workflow document with the team for reference and clarity. (Steve)
- **Data Analysis Sharing:** Finalize and share the collected data on potentially relevant AI-related CVEs from NVD with the team to facilitate focused discussion and example selection. (Steve)

- **Observed Examples Selection:** Review the shared data and suggest good observed examples for the upcoming CWE release. (Group)
- **CDR Submission:** Create a CDR submission for the selected observed examples to centralize discussions and feedback. (Steve)